

INTRODUCTION À L'AUTHENTIFICATION



Vous avez reçu un lien Google Sheet et vous souhaitez y accéder depuis un nouvel appareil.

→ Quelles sont les étapes pour y arriver ?



Connexion

Utilisez votre compte Google

Français (France)



John Doe

john@doe.com

Français (France)



Google Sheets

Une autorisation est nécessaire

Demandez l'accès ou passez à un compte accédé. [En savoir plus](#)

Message (facultatif)

[Demande d'accès](#)





Feuille de calcul sans titre

Fichier Édition Affichage Insertion Format Données Outils Extensions Aide

100% 123 Par dé... 10 B

A1	A	B	C	D	E	F
1	Tapez "@" suivi d'un nom pour insérer un chip de contact intelligent					
2						
3						
4						
5						
6						
7						
8						
9						

→ MODÈLE IAAA

MODÈLE IAAA

1. IDENTIFICATION

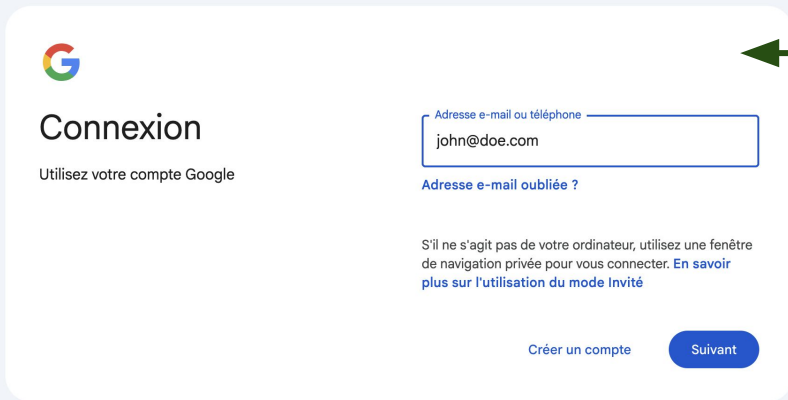
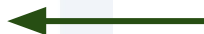
“Qui est la personne ou le système qui tente d’accéder au service ?”

→ souvent via un e-mail ou un nom d'utilisateur

2. AUTHENTICATION

“Est-ce qu’il s’agit bien de la personne qu’elle prétend être ?”

→ souvent via un mot de passe, un lien à usage unique, de la biométrie, ...



Google logo

Connexion

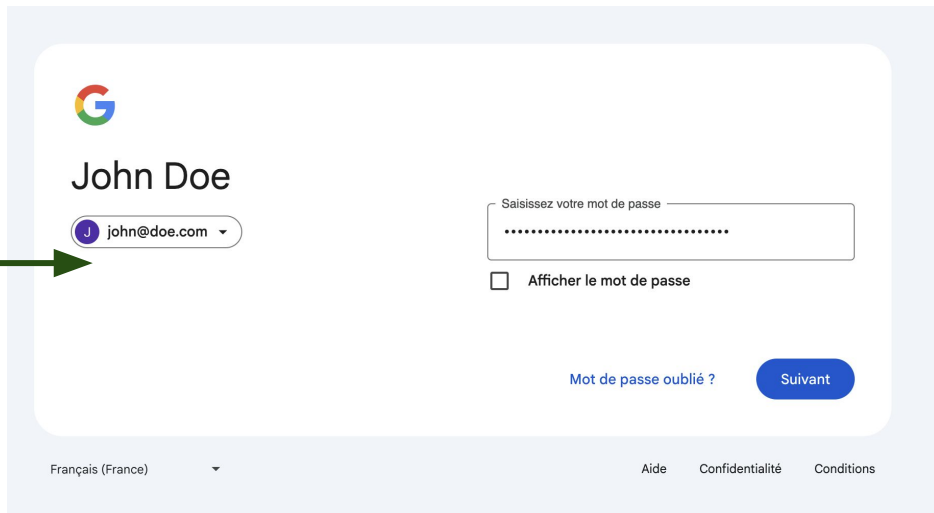
Utilisez votre compte Google

Adresse e-mail ou téléphone
john@doe.com

[Adresse e-mail oubliée ?](#)

S'il ne s'agit pas de votre ordinateur, utilisez une fenêtre de navigation privée pour vous connecter. [En savoir plus sur l'utilisation du mode Invité](#)

[Créer un compte](#) [Suivant](#)



Google logo

John Doe

john@doe.com

Saisissez votre mot de passe

☐ Afficher le mot de passe

[Mot de passe oublié ?](#) [Suivant](#)

MODÈLE IAAA



Une autorisation est nécessaire

Demandez l'accès ou passez à un compte autorisé à y accéder. [En savoir plus](#)

Message (facultatif)

Demande d'accès



3. AUTHORISATION

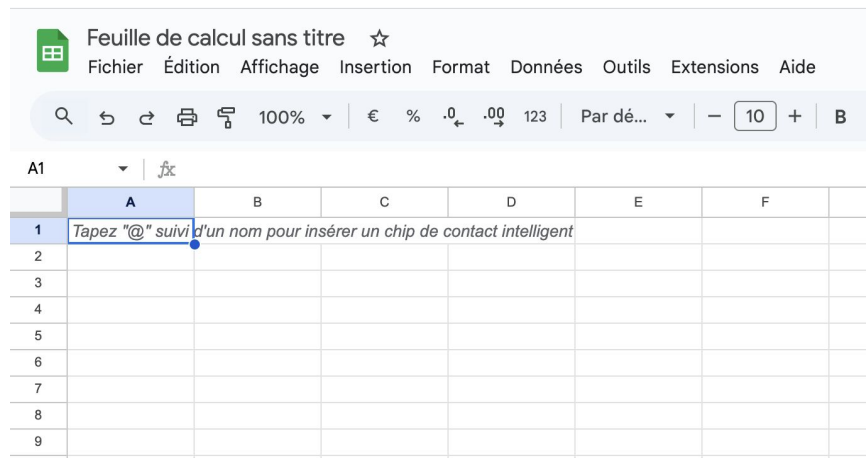
“Est-ce que cette personne ou ce système a le droit d'accéder à cette partie du service ?”

→ souvent via des rôles et des permissions

4. ACCOUNTABILITY



Enregistrer les accès à la ressource et les différentes actions réalisées



Identifier avec fiabilité et unicité



- **Nom de famille**
→ 95% des personnes partagent leur nom de famille avec une autre personne
- **Nom + Prénom**
→ 6% des personnes partagent leur nom + prénom avec une autre personne
- **Nom + Prénom + Date de naissance**
→ 795 personnes (0.01%) partagent leur nom + prénom + date de naissance complète avec une autre personne



- Adresse e-mail
- Numéro de téléphone
- Numéro d'identification unique :
 - SIRET
 - N° de membre
 - N° de réservation
 - ...

Authentifier uniquement avec un mot de passe n'est pas suffisant

Mots de passe les plus utilisés en 2024

- 123456789
- 123456
- admin
- Qwerty
- welcome
- Password
- Password1
- p@sswOrd
- 12345
- Qwerty123
- 1q2w3e
- 12345678
- 111111

Authentifier uniquement avec un mot de passe n'est pas suffisant



Coupe du monde du Brésil 2014

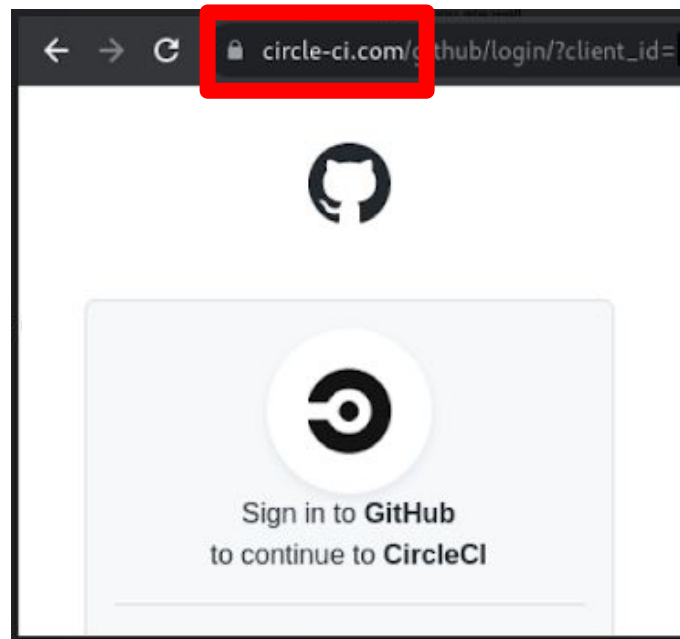


UK weather emergency

Authentifier uniquement avec un mot de passe n'est pas suffisant

En septembre 2022, des messages frauduleux invitent à se rendre sur "circle-ci.com" (typosquatting de "circleci.com")

- vol des mots de passe des comptes GitHub
- création de clés API pour persister
- vol et modification de codes sources



Authentifier uniquement avec un mot de passe n'est pas suffisant

Info-stealers

→ Exfiltration de l'ensemble
des mots de passe pro et perso



Simple Extended @cpe.fr| Search

Showing documents: **1 — 10** of **>10000**

Your search returned more than 10'000 entries. We show only the first 10'000 entries.

MÉTHODES D'AUTHENTIFICATION

→ Quelles méthodes connaissez-vous ?

Ce que je sais

 Mot de passe

 Code PIN

 Questions de sécurité

Ce que je possède

 SMS / Appel

 Code TOTP

 Lien ou code par e-mail

 Clé de sécurité (Yubikey)

 Certificat numérique

 Lettre recommandée (banques)

Ce que je suis

 Empreintes digitales

 Reconnaissance faciale

 Reconnaissance vocale.

→ **Authentification “forte” ou “multiple facteurs” (MFA)** : au moins 2 catégories sur 3 sont vérifiées
(ex : mot de passe + code TOTP)



Attention aux vérifications par téléphone

Appel sur votre téléphone, un code est donné par téléphone qu'il faut entrer sur le site web

→ Où va le code de vérification sur vous ne répondez pas ? 😊

What's your mobile number?

We will send a verification code to (415) 401-5186

To complete your phone number verification, enter the 6-digit verification code.

[Send via SMS](#)

[Call me instead](#)

[CANCEL](#)

How would you like to change your password?

Let us know how you prefer to verify your identity

☒ Send me an email

☐ Text my phone number ending in 86

☐ Call my phone number ending in 86

[Cancel](#) [Submit](#)

Google

2-Step Verification

 tompromise@gmail.com

Try another way to sign in

 Call your phone on file (...)86

 Get help
For security reasons, this may take 3-5 business days

Attention aux vérifications par téléphone

→ Qui connaît le code PIN de sa messagerie vocale de téléphone ?

- Accessible depuis n'importe quel pays
- Code PIN de 4 chiffres seulement
- Peu de protections anti brute-force
- Possibilité de paralléliser les appels



Attention aux vérifications par téléphone → SIM swapping

1. Obtenir les données personnelles (OSINT, leaks, ...)
2. Usurper l'identité auprès de l'opérateur
3. Obtenir une nouvelle carte SIM (ou une seconde)

OSINT



Leak d'identifiants
opérateur mobile



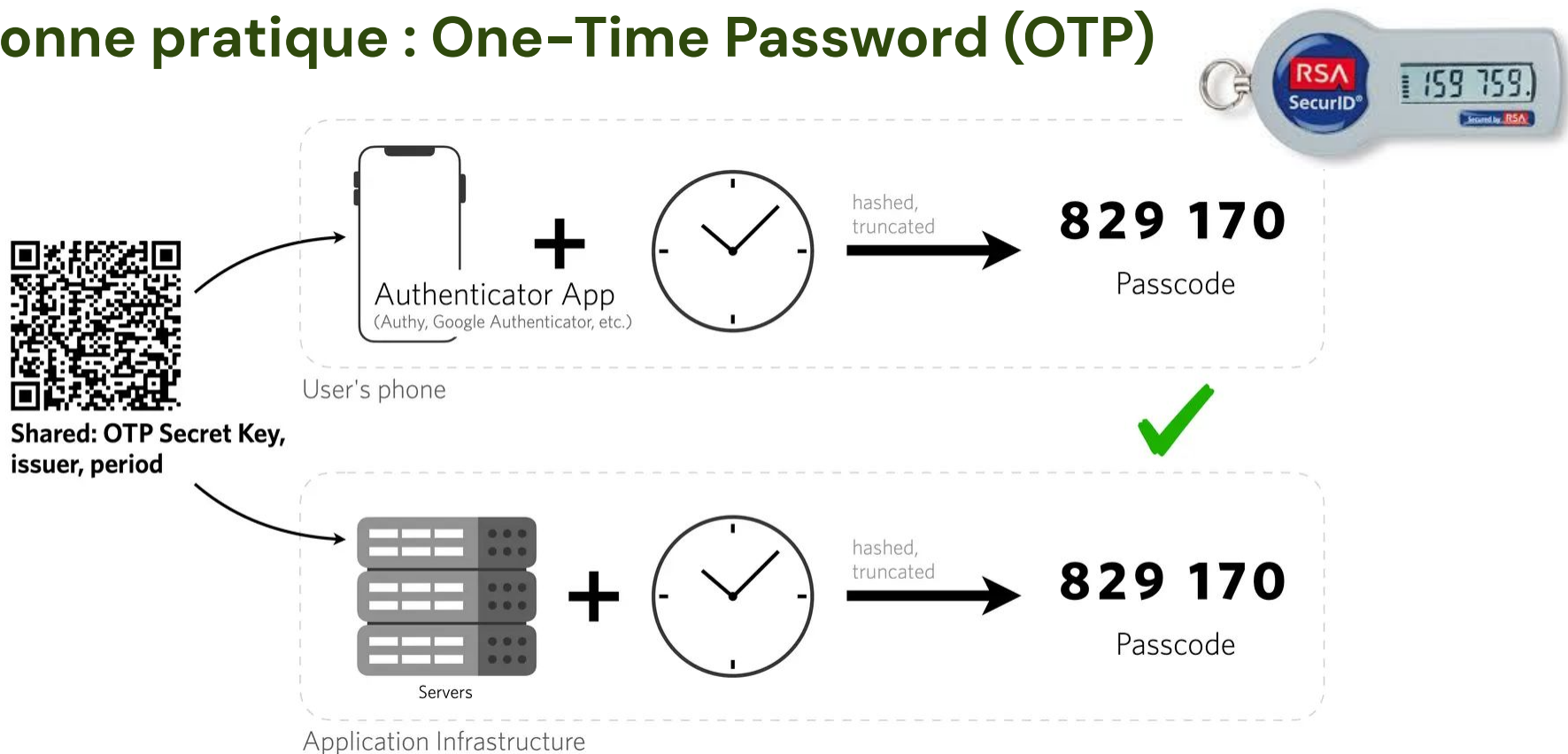
Phishing
Social engineering



 **Achievement Get!**
La carte SIM du voisin



Bonne pratique : One-Time Password (OTP)



→ Bien synchroniser l'heure de son téléphone 🕒



Modèle IAAA



Identification

Fiable et unique (pas d'état civil)



Authentication

Un mot de passe n'est pas suffisant

À minima deux facteurs (2FA) parmi ce que je sais,
ce que je suis et ce que je possède (idéalement OTP ou Yubikey)
Si possible, éviter par téléphone ou par SMS



Authorization

Utiliser des JWT (contient user ID, rôles et groupes)
à expiration courte, couplés à des refresh tokens



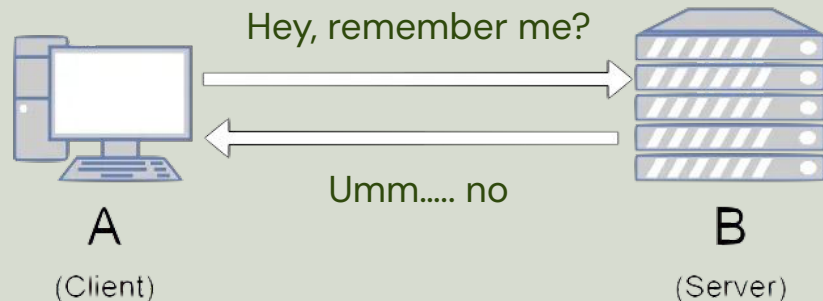
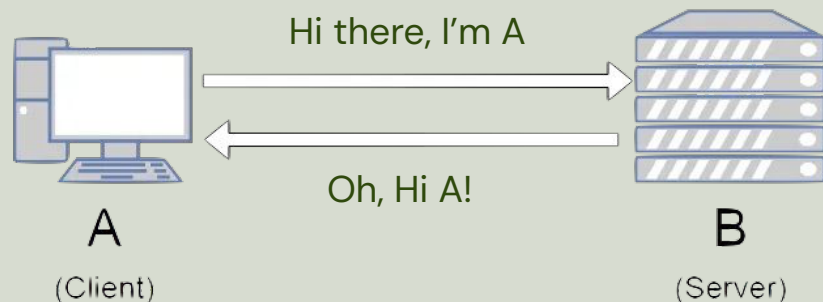
Accountability

Tracer chaque tentative de connexion (échouée ou réussie)
Mettre en place des mécanismes anti-bruteforce (rate limit)

Le protocole HTTP est "stateless"

Nativement :

- Chaque requête HTTP est traitée séparément
 - Aucune mémorisation du contexte ou des requêtes passées
- Il faut pouvoir identifier chaque utilisateur parmi toutes les requêtes entrantes, et qu'il n'ait pas à se ré-authentifier à chaque requête, **sans stocker ses identifiants en clair sur le client**
- Utilisation de sessions ou de JWTs



Stateful par sessions

Identifiant unique de session généré lors de la requête de connexion, transmis à chaque requête suivante.

Stockage des informations de l'utilisateur sur le serveur (fichier, BDD, ...).

→ Exemple : PHP Sessions

- ✓ Simple pour révoquer une session
- ✓ Moins de risque d'usurpation d'identité

✗ Difficilement scalable à grande échelle (stockage partagé entre les différents serveurs, grand volume de données, ...)



Client



Serveur

Authentication
login = kate, pass = *****

Identifiant de session
session_id = a79fh3o

Requêtes suivantes
session_id = a79fh3o

Utilisateur connu
Kate

**Stockage des
infos de session**

session a79fh3o :
login = kate
role = admin
...

**Lecture des
infos de session**
a79fh3o = Kate

Stateful par JSON Web Tokens (JWT)

Token généré et signé lors de la requête de connexion, qui contient les informations de l'utilisateur (identifiant, email, rôles et permissions), transmis à chaque requête pour déterminer ses permissions

- ✓ Sécurisé si bonne gestion de la signature
- ✓ Flexible et scalable à grande échelle
- ✗ Peut contenir des informations sensibles
- ✗ Plus complexe de révoquer une session
- ✗ Usurpation d'identité en cas de mauvaise vérification de la signature



Client



Serveur

Authentification
login = kate, pass = *****



Génération et signature d'un JWT

Aucune information
n'est stockée sur le
serveur

JWT
token = eyJhbGciOi...



Requêtes suivantes
token = eyJhbGciOi...

JWT



Débugger :
jwt.io

eyJ0eXAiOiSU0EifQ.eyJpYXQiOi0dHJ1ZQp9.KMUFsIDTnFmQV30

Header

base64

```
{  
  "typ": "JWT",  
  "alg": "HS256"  
}
```

Payload

base64

```
{  
  "iat": 1516239022,  
  "exp": 1516239622,  
  "aud": "myapp",  
  "sub": "1",  
  "name": "Kate",  
  "admin": true  
}
```

Signature

alg

```
signature = alg("<header>.<payload>")
```

Calculée en utilisant l'algorithme *alg* défini dans le header

Seul le serveur connaît la clé secrète utilisée avec l'algorithme

→ Garantit l'**intégrité** des informations



JSON Web Token

Payload d'un JWT

eyJ0eXAiOiSU0EifQ.eyJpYXQiO0dHJ1ZQp9.KMUFsIDTnFmQV30

Header

Payload

Signature

```
{
  "iat": 1516239022,
  "exp": 1516239622,
  "aud": "myapp",
  "sub": "1",

  "name": "Kate",
  "admin": true
}
```

Claims standards (définis dans la RFC7519)

issued at – timestamp de génération (secondes UNIX)
expiration – timestamp d'expiration (secondes UNIX)
audience – destinataire(s) du token (string ou array)
subject – identifiant du sujet (généralement l'ID de l'utilisateur)
... ([autres claims standards : auth0.com](https://auth0.com))



Claims personnalisés

Toutes les clés/valeurs sont possibles, en général ce qui est utilisé par la majorité des requêtes (nom, prénom, e-mail, rôles, groupes, ...)

- Tous les claims sont **optionnels**, c'est en fonction de vos besoins
À minima, les claims standards ci-dessus sont **fortement recommandés** pour la sécurité

Signature d'un JWT

eyJ0eXAiOiSU0EifQ.eyJpYXQiO0dHJ1ZQp9.KMUFsIDTnFmQV30

Header

Payload

Signature

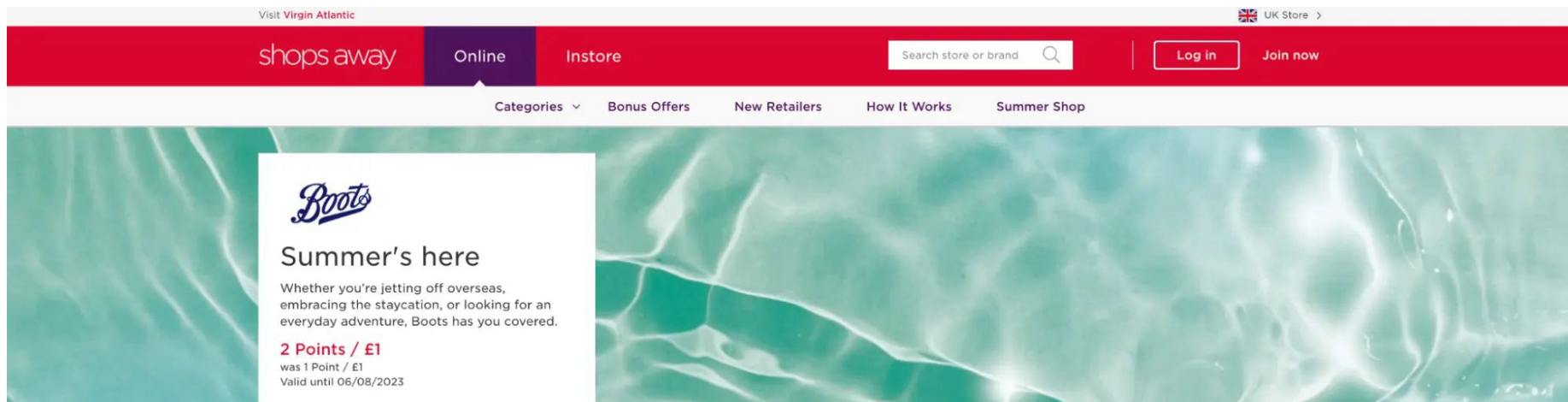
Chiffrement	Génération de la signature	Vérification de la signature
Symétrique alg : HMAC (HS256, HS512, ...) Adapté si la même application génère et vérifie la signature	 Secret commun	
Asymétrique alg : RSA (RS256, RS512, ...), ECDSA Adapté si une application génère la signature et une ou plusieurs autres applications vérifie la signature (SSO)	 Clé privée	 Clé publique



Hacking the Largest Airline and Hotel Rewards Platform

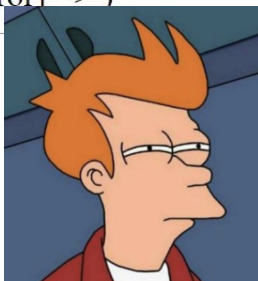
vulnérabilité découverte en août 2023

Source : samcurry.net/points-com



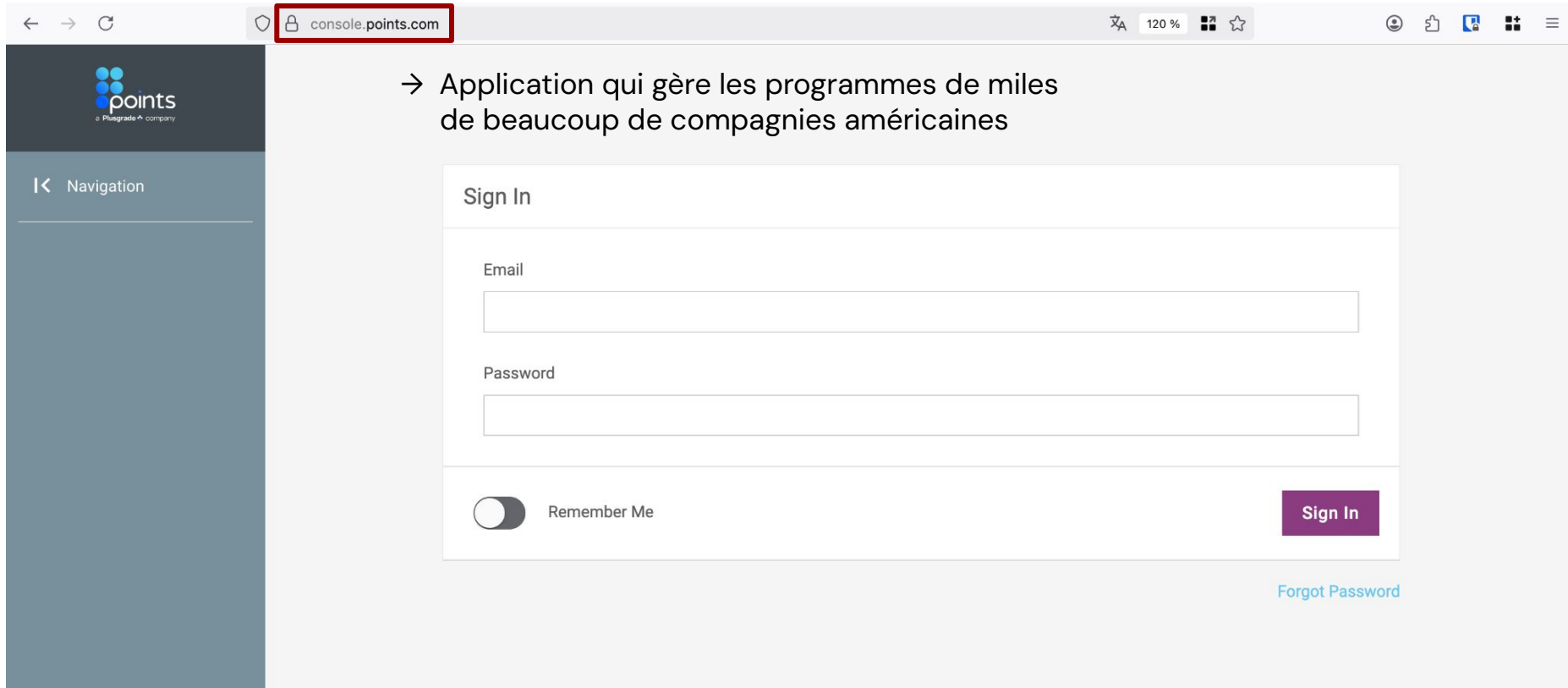
shopsaway.virginatlantic.com/login1.php

Points_LCP Object ([request] => https://lcp.points.com/v1/lps/9a0caf31-feeb-48c3-87a1-6ebe6de4c0fa/mvs/[redacted]?expand=member-details [requestData] => [] [response] => { "application": "https://lcp.points.com/v1/apps/4dca49ff-c964-4d5c-be96-9eb66c7cc030", "balance": 4398, "createdAt": "2023-05-03T02:09:42.112207Z", "identifyingFactors": { "firstName": "[redacted]", "lastName": "[redacted]", "memberId": "[redacted]" }, "links": { "memberDetails": { "href": "https://lcp.points.com/v1/lps/9a0caf31-feeb-48c3-87a1-6ebe6de4c0fa/mvs/[redacted]/member-details" }, "self": { "href": "https://lcp.points.com/v1/lps/9a0caf31-feeb-48c3-87a1-6ebe6de4c0fa/mvs/[redacted]" } }, "loyaltyProgram": "https://lcp.points.com/v1/lps/9a0caf31-feeb-48c3-87a1-6ebe6de4c0fa", "memberDetails": { "balance": 4398, "firstName": "[redacted]", "lastName": "[redacted]", "memberId": "[redacted]" }, "status": "success", "type": "memberValidation", "updatedAt": "2023-05-03T02:09:43.430074Z" } [id] => 9a0caf31-feeb-48c3-87a1-6ebe6de4c0fa [url] => https://lcp.points.com/v1/lps/9a0caf31-feeb-48c3-87a1-6ebe6de4c0fa [macID] => [redacted] [macKey] => [redacted] [ssoKey] => [redacted] [appID] => [error] =>)

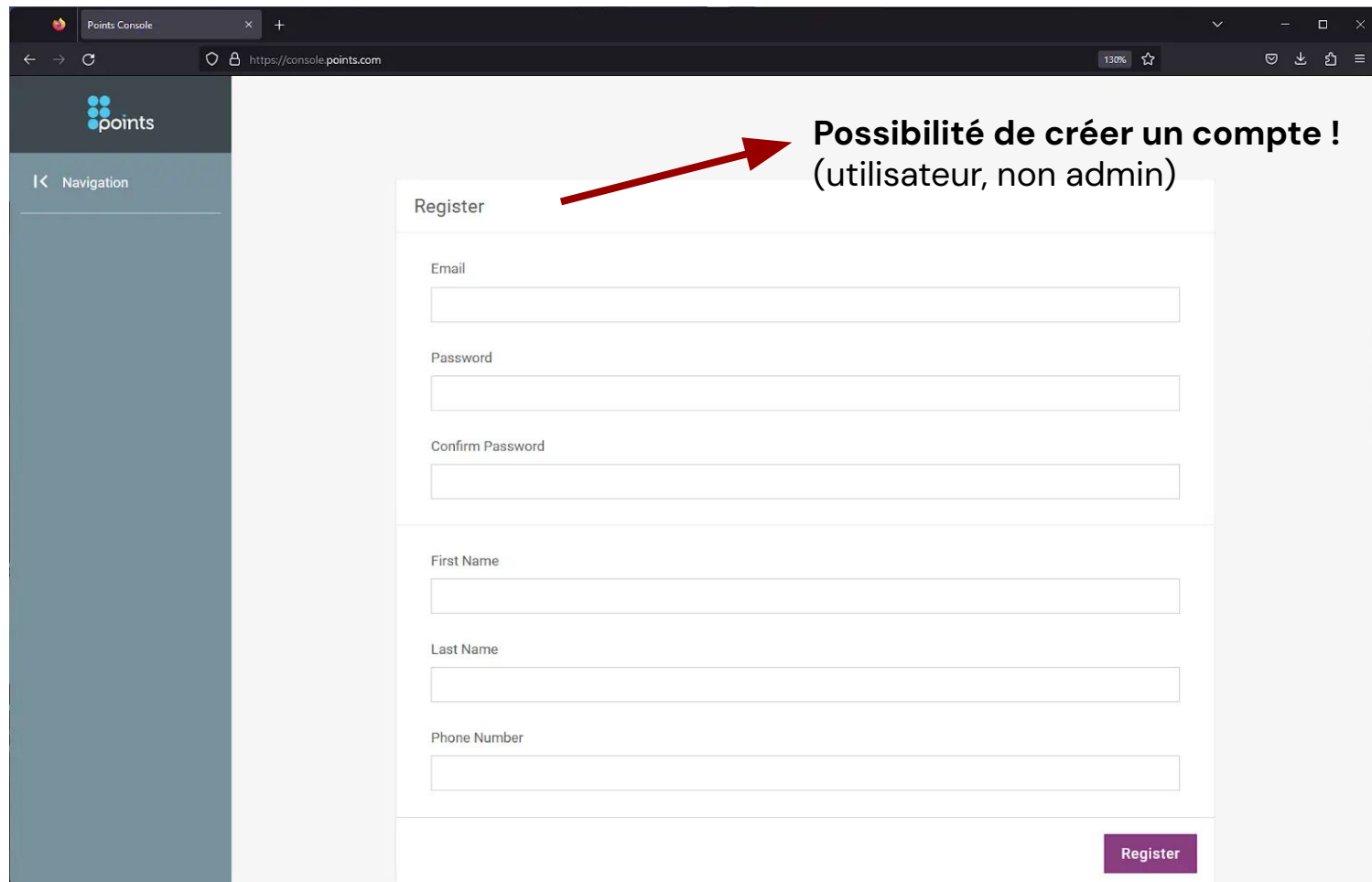


points.com ?

→ Application qui gère les programmes de miles de beaucoup de compagnies américaines



The screenshot displays a web browser window with the address bar showing 'console.points.com'. The page layout includes a dark sidebar on the left with the 'points' logo and a 'Navigation' link. The main content area is light gray and contains a 'Sign In' form. The form has two input fields labeled 'Email' and 'Password', a 'Remember Me' toggle switch, and a purple 'Sign In' button. Below the form, there is a blue link for 'Forgot Password'.



The screenshot shows a web browser window with the address bar displaying `https://console.points.com`. The page has a dark sidebar on the left with the 'points' logo and a 'Navigation' link. The main content area is titled 'Register' and contains a form with the following fields:

- Email
- Password
- Confirm Password
- First Name
- Last Name
- Phone Number

A red arrow points from the text 'Possibilité de créer un compte ! (utilisateur, non admin)' to the 'Register' link in the top right corner of the form area. At the bottom right of the form, there is a purple button labeled 'Register'.

→ Tentative de découverte du secret

```
z1z@htp ~> cookiemonster -cookie ".eJwNyTE0gzAMBdC7e06QGNskXCZKrG8hgVqJdEPcvX3ru6n5vKJ9Pw"
🍪 CookieMonster 1.4.0
ℹ CookieMonster loaded the default wordlist; it has 38919 entries.
✅ Success! I discovered the key for this cookie with the flask decoder; it is "secret".
```



points

Navigation

Account

Organizations

Orders

Manual Bonus

Loyalty Platform

API Documentation

Logout

Manual Bonus

Bulk Orders

Single Orders

Approvals

1 Single Orders

Loyalty Program URL

Required

Ticket

Offer URL

Parent Order URL

Amount

Member ID

Application

Manifest

Service Workers

Storage

Local Storage

Session Storage

IndexedDB

Web SQL

Cookies

Trust Tokens

Interest Groups

Shared Storage

Filter

Only show cookies with an issue

Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly	Secure	SameSite	Partition Key	Priority
_cf_bm	LC.bxJf...	.points.com	/	2023-05-02T06:57...	152	✓	✓	None		Medium
_csrf_token	bb2c...	console.poin...	/	2023-05-02T07:32...	75	✓	✓	Lax		Medium
session	.ajYVUU13DAU_C86Z7OSrA97cdBSaglUEkplAWYp6cni7v-lmWnXUL-e5...	console.poin...	/	2023-05-02T07:32...	705	✓	✓			Medium
cookiesession1	678A3E137FFB024178E56416A9F906A	console.poin...	/	2024-05-01T08:22...	46	✓	✓			Medium

Select a cookie to preview its value

Loyalty Platform

User Support

Ian Carroll | ian@ian.sh Account Enabled, created on Mar 13th, 2019 7:33pm
ID# 8806686c-ade4-40b5-ba70-9727d4d363e9

[back](#)

[Account Info](#)

[History](#)

[Memberships](#)

[Notes](#)

Transactions

[Connections](#)

Transactions

Date	Confirmation/OrderID	Summary	Actions
Jun 19, 2021 07:22 am	- Order#1517-4447-4764-3617-6867 - ID: 8c19c0a5-0680-4f58-86e9-547a032515e5	- EARN, Order status: complete - Earned 89 <i>Hilton Honors</i> Points [Account: 1062269251] - Email for confirmation: ian@ian.sh - Ready to credit from: Jun 19, 2021 - Credit Expiry Date: Aug 18, 2021 - Original Order Number: 1553841147920144344 - Product Code: lyft	
Jun 14, 2021 06:30 am	- Order#5602-8076-2432-3747-5338 - ID: 4cdc1e98-91ae-4a17-b1c6-181d257ca704	- EARN, Order status: complete - Earned 62 <i>Hilton Honors</i> Points [Account: 1062269251] - Email for confirmation: ian@ian.sh - Ready to credit from: Jun 14, 2021 - Credit Expiry Date: Aug 13, 2021 - Original Order Number: 1551972791998978684 - Product Code: lyft	
		- EARN, Order status: complete - Earned 26 <i>Hilton Honors</i> Points [Account: 1062269251]	

Principaux risques de sécurité d'un JWT



Secret/Clé de la signature trop faible

Risque : Cassage du secret pour en forger une nouvelle et altérer le payload

Remédiation : Utiliser un secret robuste et stocké de manière sécurisée

Exemple avec *hashcat* :

```
hashcat -a 0 -m 16500 "eyJ..." ./rockyou.txt
```



Mauvaise vérification de la signature

Risque : Altération possible du payload (modification de l'utilisateur, des rôles, ...)

Remédiation : Vérifier la signature avec une librairie dédiée, et pas uniquement décoder



Pas d'expiration des JWT ou expiration trop longue

Risque : Ré-utilisation d'un JWT dans des cookies fuités (info-stealer) et re-jeu

Remédiation : Définir une expiration courte (10 minutes) et utiliser des Refresh Tokens

Stocker un JWT



Dans le *localStorage* ou *sessionStorage*

→ Lisible et exfiltrable facilement avec JavaScript



En mémoire (dans une variable front-end)

→ Lisible et exfiltrable facilement avec JavaScript (même avec React, Vue ou Angular)



Dans un cookie

→ Inaccessible avec JavaScript si **HttpOnly=true** (le navigateur l'envoie automatiquement)

→ Utiliser **SameSite=strict** pour ne pas le partager avec les autres sous-domaines

→ Utiliser **Secure=true** pour l'envoyer uniquement en HTTPS